

Annual enterprise risk assessment

The group completes an annual top-down risk assessment led by the Executive Committee. Executives identify external, strategic, financial, operational, compliance, and people risks that could prevent delivery of the group plan. An internal regulatory instrument governs the ERM process. The Chief Risk Officer is the named leader responsible for it, supported by dedicated risk staff and resources.

In parallel, every business unit completes a bottom-up risk assessment through facilitated workshops, and subsidiaries participate in the bottom-up risk assessment. Risk owners describe causes, potential consequences, existing controls, likelihood, impact, and planned response.

The Risk and Compliance Office provides common definitions and challenges unsupported ratings so that risks from different units can be compared on a consistent basis.

Consolidation and strategy integration

The Risk and Compliance Office consolidates the two assessment streams into an enterprise risk register. Similar exposures are grouped, cross-business dependencies are recorded, and one executive owner is assigned to each principal risk.

Before the group plan is finalized, the Planning and Performance Office reviews the register with risk owners. Strategic choices are adjusted when risk exposure exceeds the agreed appetite or when a response requires additional resources.

The final strategy paper describes the principal assumptions and linked risk responses; the strategic plan outlines the risks that could threaten company objectives. This makes risk assessment an input to strategic planning rather than a separate year-end exercise. The regulatory system governs the interaction between risk analysis and strategic planning, so their formal integration is part of the approved procedure.

Risk governance and reporting

The Risk Committee is formally appointed to support the Executive Committee. It reviews the enterprise risk register, confirms ownership, challenges the adequacy of responses, and decides which exposures require escalation. Decisions and action owners are recorded in the committee minutes.

The committee prepares a Board risk report summarizing the principal risks, direction of exposure, control concerns, mitigation progress, and decisions requested. The report accompanies the annual strategic plan.

The risk profile is presented to and analyzed by the Board as part of strategic plan approval. Risk assessment results and related responses are reported to the Board and control bodies, and approved decisions go to the business units.

Risk response follow-up

Principal risk owners maintain response plans with milestones, resources, responsible managers, and completion dates. The Risk and Compliance Office reviews progress quarterly and follows up overdue actions.

New or materially changed exposures can be raised outside the annual cycle through the operational escalation process. The responsible executive assesses the change and requests a Risk Committee decision when necessary.

At the end of the cycle, the office compares planned responses with actual completion and records lessons for the next assessment. Significant control gaps remain open until corrective evidence is verified. ERM is integrated with Finance, HSE, Cyber, Compliance, and Project risk processes. Risk analyses enter integrated financial and sustainability reporting and appear in periodic financial reports and the sustainability report.